

David O'Neal – MS, Cybersecurity

(501) 749-4031 onealdavide@gmail.com

linkedin.com/in/david-oneal Portfolio: davidoneal.dev GitHub: github.com/doneal78

Certified GRC Engineer – Auditor Specialty

EXECUTIVE SUMMARY

Certified GRC Engineer (Auditor Specialty) with 8+ years across compliance, risk management, and security operations in financial services, government, and MSSP consulting. Builds automated compliance controls using Terraform, OPA/Rego, GitHub Actions, Cosign, and OSCAL to replace manual audit work with engineered assurance. Portfolio includes an end-to-end NIST 800-53 compliance pipeline with a verifiable evidence chain of custody. Targeting GRC Engineer, Compliance Engineer, and DevSecOps Engineer (compliance focus) roles.

PROJECTS

Name: GRC Engineering Pipeline

Built an evidence-first CI/CD pipeline enforcing NIST 800-53 controls (SC-28, AC-3, CM-6, AU-3) on AWS S3. Terraform defines the infrastructure; six Rego policies via OPA/Conftest test the plan before deployment; GitHub Actions blocks non-compliant PRs with branch protection; Cosign performs keyless signing of evidence artifacts with a Sigstore chain of custody; OSCAL 1.2.1 component definitions map every control to its evidence and validate with compliance-trestle.

Tools: Terraform, OPA/Rego, Conftest, GitHub Actions, Cosign, Sigstore, AWS (S3, CloudTrail, KMS, IAM), Python, OSCAL, compliance-trestle

Proof: 6/6 policy tests passing; merged compliant PR and a deliberately blocked regression PR visible in commit history

Source: github.com/doneal78/grc-engineering-pipeline

Name: Compliance Automation Lab

Built an AWS S3 and IAM configuration scanner using Python and boto3 against a Terraform baseline, producing a before/after compliance score with root-cause detail on every failure.

Tools: Python, boto3, Terraform, AWS S3, AWS IAM, AWS Security Hub

Proof: Terraform baseline moved from 40% (AT RISK) to 78% (NEEDS IMPROVEMENT); remaining gap traced to one intentionally misconfigured test bucket and a physical MFA device pending setup on the lab IAM user, documented rather than hidden

Source: github.com/doneal78/grc-compliance-checker

EXPERIENCE

Career Transition – GRC Engineering Portfolio Development, Remote, August 2026 – Present

- Focused on completing GRC Engineering portfolio work following departure from Legato Security
- Shipped an end-to-end compliance automation pipeline (Terraform, OPA/Rego, GitHub Actions, Cosign, OSCAL) mapped to NIST 800-53 (SC-28, AC-3, CM-6, AU-3) with 6/6 policy tests passing and verifiable merged and blocked PR history
- Actively applying to GRC Engineer and Compliance Engineer roles at financial services, regulated healthcare, government, and energy and utilities organizations

Legato Security, Project Manager (Managed Security Service Provider), September 2025 – July 2026

- Led security service delivery for 10+ enterprise client accounts, coordinating across SOC analysts, engineers, and channel partners to keep projects on track
- Built and managed onboarding workflows in GuideCX with milestone tracking that got new clients up and running faster
- Wrote Quarterly Business Reviews (QBRs) and delivery updates translating technical security work into plain language for client leadership
- Designed the connector setup workflow for Mave so engineers had a documented, repeatable process for configuring client integrations

Rehired into this role after a company-wide reduction in force ended the Cybersecurity Consultant position below; two months between roles.

Legato Security, Cybersecurity Consultant, April 2025 – July 2025

- Designed and led patch and vulnerability management programs for aerospace and industrial clients across 279+ endpoints, prioritizing CVEs by risk level and business impact
- Used Tenable.io, Nessus, and PDQ Connect to cut critical vulnerability remediation from several weeks to under 72 hours, more than 80% faster
- Built a Patching-as-a-Service delivery framework that standardized remediation across client environments and reduced manual coordination effort
- Authored patching SOPs, risk classifications, and remediation documentation to strengthen governance and audit readiness

Arkansas Department of Public Safety, State IT Security Specialist, October 2024 – March 2025

- Maintained patch compliance above 95% across 500+ endpoints through automated deployment and consistent remediation tracking
- Handled IAM for the department, including provisioning, deprovisioning, MFA resets, and access reviews in Active Directory and Azure AD
- Built vulnerability dashboards and KPI reports that gave IT leadership a clear picture of current risk

Position eliminated due to state budget reallocation.

Bank OZK, SOC Analyst, October 2021 – June 2024

- Investigated and resolved 30+ phishing, malware, BEC, and DLP incidents per week in a financial-sector SOC, completing phishing investigations in under 20 minutes while maintaining SLAs and documenting findings for audit
- Reduced phishing false-positive alerts by 40% through detection rule tuning across Proofpoint, Microsoft Defender, and Cisco SEG
- Wrote DLP response SOPs that standardized how the team handled incidents and kept everything traceable
- Worked with the security awareness team on phishing simulations and reporting habits; phishing incidents dropped 40% over the same period

FIS Global, System Operations Analyst I, June 2017 – October 2021

- Provided 24/7 enterprise systems monitoring using Splunk, responding in real time to service disruptions and supporting incident root cause analysis
- Maintained operational playbooks and documentation to support audit compliance and SLA consistency
- Coordinated with global support teams

SKILLS

Compliance Automation and Policy-as-Code: OPA/Rego, Conftest, Sigstore/Cosign, OSCAL 1.2.1, compliance-trestle, NIST 800-53, SOC 2

Infrastructure as Code: Terraform, GitHub Actions, AWS (S3, CloudTrail, KMS, IAM)

Compliance and Risk Management: Risk register management, remediation tracking, patch compliance tracking, KPI and dashboard reporting

Security Operations: SIEM tuning, phishing/malware/BEC/DLP investigation, detection engineering, incident response

Identity and Access: Active Directory, Azure AD, MFA enforcement, provisioning and deprovisioning, access reviews

Vulnerability Management: Tenable.io, Nessus, PDQ Connect, CVSS-based prioritization

Languages and Tools: Python, boto3, Bash, JSON, YAML

EDUCATION

Master of Science (MS), Cybersecurity, Maryville University

Bachelor of Science (BS), Information Technology, University of Arkansas Grantham

CERTIFICATIONS

GRC Engineering Club, Certified GRC Engineer, Auditor Specialty

SimplyCyber, GRC Jumpstart: GRC Foundations in Cybersecurity

Qualys, Vulnerability Management Detection and Response